RELATÓRIO TÉCNICO DE VULNERABILIDADES

CVEs recentes do Next.js

Lançamentos de segurança de julho a outubro de 2026

Inclui as RCEs críticas de 14/10/2026 (use cache e Image Optimization / sharp)

Data de referência: 23 de outubro de 2026
Escopo: Next.js 15.5 (Maintenance LTS) e 16.x (Active LTS) — 21 vulnerabilidades em 4 lançamentos
Fontes oficiais: blog do Next.js (nextjs.org/blog) e GitHub Security Advisories (vercel/next.js); alerta do CSA de Singapura e registros CVE

Documento de estudo. Gravidade, CVSS, versões e descrições vêm dos avisos oficiais da Vercel. Confirme sempre no aviso original antes de agir em produção.

Sumário

1. Sumário executivo **3**

2. Contexto e versões **5**

3. Atualização extraordinária de 14/10/2026 **6**

3.1 GHSA-673q-mjm6-r5xr — RCE em funções use cache que retornam typed arrays . . . 6

3.2 CVE-2026-96889 — RCE na Otimização de Imagens com SVG . . . 6

3.3 GHSA-p3m5-59mp-jv5r — DoS em App Router com Server Actions . . . 7

4. Lançamento de 25/08/2026 (críticas) **8**

4.1 GHSA-2xp9-vwfh-vxw4 — RCE na Otimização de Imagens com AVIF (libheif) . . . 8

4.2 CVE-2026-75604 — RCE em servidores Windows (path traversal) . . . 8

5. Lançamento de 30/09/2026 **9**

5.1 CVE-2026-94483 — SSRF na Otimização de Imagens . . . 9

5.2 Demais falhas de setembro . . . 9

6. Lançamento de 21/07/2026 (primeiro programado) **10**

7. Recomendações práticas **11**

Fontes de pesquisa **11**

1. Sumário executivo

Desde julho de 2026 o Next.js tem um **programa formal de lançamentos de segurança**: cerca de uma vez por mês a Vercel anuncia com antecedência a data e a gravidade máxima da próxima rodada, e publica as correções nos dois ramos suportados, **16.x (Active LTS)** e **15.5 (Maintenance LTS)**. Falhas urgentes ou exploradas continuam saindo fora do calendário.

Este relatório explica as **21 vulnerabilidades** corrigidas nas quatro rodadas desde então: 21/07, 25/08, 30/09 e a atualização extraordinária de 14/10/2026.

Principais conclusões

- **Quatro falhas críticas de execução remota de código sem autenticação** em dois meses — três na Otimização de Imagens (bibliotecas nativas `sharp`/`libheif`) ou no React, e uma em servidores Windows.
- **As duas mais recentes (14/10, CVSS 4.0 = 9,5):** RCE em funções `use cache` que retornam typed arrays (GHSA-673q-mjm6-r5xr, origem no React) e RCE na Otimização de Imagens com SVG em Linux com glibc (CVE-2026-96889, origem no `sharp`).
- **Versões seguras hoje:** `next@16.4.1` ou `next@15.5.28` (ou posteriores). Qualquer versão anterior está exposta a pelo menos uma RCE crítica.
- **A Otimização de Imagens (`/_next/image`) é o ponto mais atacado:** duas RCEs, um SSRF e um DoS no período. Quem não precisa dela pode desativá-la (`images.unoptimized: true`).
- **Server Actions:** o mesmo tipo de DoS por CPU apareceu em julho (CVE-2026-64641) e voltou em outubro (GHSA-p3m5-59mp-jv5r), agora via React.
- **Hospedagem própria pesa:** várias falhas só afetam self-hosting (Windows, glibc, cache SSG/ISR, servidor customizado). Na Vercel, parte é mitigada na plataforma, mas a recomendação oficial continua sendo atualizar.
- Não há relato de exploração ativa nem prova de conceito pública para as falhas de outubro, segundo a SecurityOnline.

Visão geral

ID	Componente	Tipo	Gravidade	Rodada
GHSA-673q-mjm6-r5xr	use cache (React)	RCE sem autenticação	Crítica 9.5 (v4)	14/10
CVE-2026-96889	Image Optimization (sharp)	RCE sem autenticação (SVG)	Crítica 9.5 (v4)	14/10
GHSA-p3m5-59mp-jv5r	Server Actions (React)	DoS por CPU	Alta 8.2 (v4)	14/10
CVE-2026-94483	Image Optimization	SSRF	Alta	30/09
CVE-2026-94543	Pages Router SSG/ISR	Envenenamento de cache	Média	30/09
CVE-2026-94484	SSG/ISR + catch-all	Envenenamento de cache / DoS	Média	30/09
CVE-2026-94485	Imagens de metadata	Divulgação de informação	Média	30/09
GHSA-h694-7cp9-m8p3	use cache aninhado	Vazamento de cache	Média	30/09
CVE-2026-94544	use cache + Draft Mode	Vazamento de rascunhos	Média	30/09
CVE-2026-94486	next dev (MCP)	Divulgação de informação	Baixa	30/09
GHSA-2xp9-vwfh-vxw4	Image Optimization (libheif)	RCE sem autenticação (AVIF)	Crítica 9.5 (v4)	25/08
CVE-2026-75604	Servidor em Windows	RCE sem autenticação (path traversal)	Crítica 9.0 (v3.1)	25/08
CVE-2026-64641	Server Actions	DoS por CPU	Alta	21/07
CVE-2026-64642	Middleware/Proxy (Turbopack)	Bypass de middleware	Alta	21/07
CVE-2026-64645	rewrites/redirects	SSRF / open redirect	Alta	21/07
CVE-2026-64649	Server Actions (custom server)	SSRF	Alta	21/07
CVE-2026-64644	Image Optimization	DoS com SVG	Média	21/07
CVE-2026-64646	Server Actions (Edge)	Consumo de memória	Média	21/07
CVE-2026-64643	Server Functions	Divulgação de IDs internos	Média	21/07
CVE-2026-64648	fetch (cache)	Confusão de cache	Média	21/07
CVE-2026-64647	fetch (cache, UTF-8)	Confusão de cache	Média	21/07

Gravidade conforme a Vercel; nota CVSS mostrada quando publicada no aviso do GitHub. Todas as datas são de 2026.

2. Contexto e versões

Linhas de versão e correções por rodada

Rodada	16.x (Active LTS)	15.5 (Maintenance LTS)	Destaque
21/07/2026 (primeira programada)	16.2.11	15.5.21	4 altas + 5 médias
25/08/2026 (antecipada em 1 dia)	16.3.3	15.5.24	2 críticas (AVIF e Windows)
30/09/2026	16.3.8	15.5.27	1 alta + 6 médias/baixa; 2 correções adiadas
14/10/2026 (extraordinária)	**16.4.1**	**15.5.28**	2 críticas + 1 alta (as adiadas de setembro)

As correções são cumulativas: instalar a versão de outubro cobre todas as anteriores. Versões fora desses dois ramos (14.x e anteriores) não recebem correção e estão afetadas pela maioria das falhas que atingem desde a 10.x ou 13.x.

Por que tantas falhas agora

Ao anunciar o programa, a Vercel citou o aumento rápido de pesquisa de vulnerabilidades assistida por IA — mencionando que a Mozilla divulgou 271 falhas numa única versão do Firefox, todas encontradas pelo Mythos Preview da Anthropic — e informou que roda o mesmo tipo de ferramenta (deepsec) contra o Next.js. O programa também é uma resposta ao **React2Shell**, a RCE crítica divulgada em dezembro de 2025.

Glossário

Termo	Significado
App Router / Pages Router	Os dois sistemas de rotas do Next.js. O App Router (pasta `app/`) é o moderno, com React Server Components; o Pages Router (`pages/`) é o antigo.
Server Actions / Server Functions	Funções marcadas com `'use server'` que o navegador chama diretamente; o Next.js cria endpoints internos para elas.
Cache Components / use cache	Recurso que guarda em cache o resultado de funções e componentes marcados com `'use cache'`. O resultado é serializado — e falhas de serialização viram RCE.
Image Optimization	O endpoint `/_next/image` redimensiona e converte imagens sob demanda usando a biblioteca nativa `sharp` (que usa libvips, libheif, librsvg).
SSG / ISR	Páginas geradas no build (SSG) ou regeneradas periodicamente (ISR), servidas a partir de um cache compartilhado.
Middleware / Proxy	Código que roda antes da rota — muito usado para autenticação. Um bypass deixa páginas protegidas abertas.
Self-hosting	Rodar o Next.js no próprio servidor (`next start`, Docker) em vez de na Vercel.
SSRF	Server-Side Request Forgery: o atacante faz o servidor acessar endereços que ele escolhe, como a rede interna ou o serviço de metadados da nuvem.

3. Atualização extraordinária de 14/10/2026

Anunciada em 07/10 e publicada em 14/10, traz as duas correções adiadas de setembro por atraso em dependências (React e `sharp`). O CSA de Singapura emitiu o alerta AL-2026-148 sobre ela.

3.1 GHSA-673q-mjm6-r5xr — RCE em funções use cache que retornam typed arrays

GHSA-673q-mjm6-r5xr	CRÍTICA · CVSS 4.0 9.5
Título oficial	Unauthenticated Remote Code Execution in use cache functions returning typed arrays
Vetor	`CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:N`
CVE	Ainda não atribuída
Versões afetadas	next 16.0.0 a 16.4.0 (a 15.5 não usa Cache Components)
Corrigido em	16.4.1
Origem	React — aviso upstream GHSA-xqc2-xf4c-x3h3

O que identifica

Afeta aplicações com **App Router e Cache Components**. Quando uma função `'use cache'` retorna **vários typed arrays** (`Uint8Array`, `Float32Array` etc.), o resultado é serializado pelo protocolo do React (o mesmo do React Server Components) e a desserialização pode ser manipulada por um atacante para executar código no servidor.

É a mesma família do React2Shell (dezembro de 2025): falhas no formato de serialização do React viram execução de código.

Impacto

Execução remota de código sem autenticação no servidor da aplicação, com impacto também em sistemas subsequentes (SC/SI altos).

Correção e mitigação

Não há contorno. A Vercel orienta atualizar para 16.4.1 **mesmo que a aplicação não tenha funções desse tipo**.

3.2 CVE-2026-96889 — RCE na Otimização de Imagens com SVG

CVE-2026-96889	CRÍTICA · CVSS 4.0 9.5
Título oficial	Unauthenticated RCE in Next.js Image Optimization with SVG files
Aviso	GHSA-2464-fhr4-w9xw
Vetor	`CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H`
Versões afetadas	10.0.0 a 15.5.27 e 16.0.0 a 16.4.0
Corrigido em	15.5.28 e 16.4.1 (que exigem `sharp` ≥ 0.35.5)
Origem	Biblioteca de imagens usada pelo `sharp`

O que identifica

Uma falha de **memória** numa biblioteca usada pela Otimização de Imagens permite executar código ao processar um **SVG** preparado. Só ocorre quando o Next.js roda em **Linux com glibc** (Debian, Ubuntu, RHEL; imagens Docker baseadas em Alpine usam musl).

Impacto

RCE sem autenticação no servidor que processa imagens. O atacante precisa que o endpoint `/_next/image` aceite a imagem — por exemplo, por `images.remotePatterns` apontando para um domínio onde ele consiga hospedar o arquivo.

Correção e mitigação

Atualizar o Next.js (o gerenciador de pacotes passa a trazer o `sharp` corrigido). Contorno oficial: garantir `sharp` ≥ 0.35.5 (`npm ls sharp`). Paliativos: restringir `remotePatterns` e manter `dangerouslyAllowSVG` desativado.

3.3 GHSA-p3m5-59mp-jv5r — DoS em App Router com Server Actions

GHSA-p3m5-59mp-jv5r	ALTA · CVSS 4.0 8.2
Título oficial	Denial of Service in App Router using Server Actions
Vetor	`CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N`
Versões afetadas	13.0.0 a 15.5.27 e 16.0.0 a 16.4.0
Corrigido em	15.5.28 e 16.4.1
Origem	React — GHSA-h3gv-c5rc-p453

O que identifica

Requisições forjadas para qualquer aplicação com App Router e **ao menos uma Server Action** provocam uso excessivo de CPU. Como o Node.js processa as requisições numa única thread, o processo inteiro deixa de responder. Pages Router ou apps sem Server Actions não são afetados.

Impacto

Negação de serviço sem autenticação com poucas requisições. É a reincidência, via React, da CVE-2026-64641 de julho.

Correção e mitigação

Atualizar. Paliativos: limite de taxa no proxy/WAF para requisições POST com cabeçalho `Next-Action` e vários processos/réplicas com reinício automático.

4. Lançamento de 25/08/2026 (críticas)

Previsto para 26/08 com uma crítica, foi antecipado para 25/08 quando a Vercel identificou uma segunda falha crítica numa dependência. Versões: **16.3.3** e **15.5.24**.

4.1 GHSA-2xp9-vwfh-vxw4 — RCE na Otimização de Imagens com AVIF (libheif)

GHSA-2xp9-vwfh-vxw4	CRÍTICA · CVSS 4.0 9.5
Título oficial	Unauthenticated Remote Code Execution in Image Optimization API when AVIF files are used
Vetor	`CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H`
CVE	Não atribuída no aviso
Versões afetadas	10.0.0 a <15.5.24 e <16.3.3
Corrigido em	15.5.24 e 16.3.3
Origem	libheif (usada pelo sharp) — GHSA-g89c-p67h-r497

O que identifica

Uma falha na **libheif**, a biblioteca que o `sharp` usa para ler imagens HEIF/AVIF, permite executar código quando o Next.js otimiza uma imagem AVIF controlada pelo atacante.

Impacto

RCE sem autenticação e sem interação do usuário no servidor de imagens.

Correção e mitigação

Atualizar. As versões corrigidas **desativam a otimização de AVIF** até a correção da libheif se propagar — imagens AVIF passam a ser servidas sem otimização.

4.2 CVE-2026-75604 — RCE em servidores Windows (path traversal)

CVE-2026-75604	CRÍTICA · CVSS 3.1 9.0
Título oficial	Unauthenticated Remote Code Execution on windows-hosted servers
Aviso	GHSA-p293-qw3h-jr36
Vetor	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H`
Fraqueza (CWE)	CWE-22: path traversal
Versões afetadas	13.4 a <15.5.24 e 16.0 a <16.3.3
Corrigido em	15.5.24 e 16.3.3
Relator	B0RI

O que identifica

Em aplicações que usam **Pages Router e App Router juntos**, sem Cache Components, um path traversal permite executar código quando o servidor roda num **sistema de arquivos Windows**. Linux e macOS não são afetados. O tratamento de separadores (\) e de caminhos do Windows é o ponto de falha típico.

Impacto

RCE sem autenticação em servidores Next.js hospedados em Windows (IIS com iisnode, Windows Server, máquinas de desenvolvimento expostas).

Correção e mitigação

Não há contorno. Atualizar imediatamente se o servidor roda em Windows.

5. Lançamento de 30/09/2026

Versões **16.3.8** e **15.5.27**. Uma falha crítica e uma alta foram adiadas por atraso em dependências e saíram em 14/10 (seção 3).

5.1 CVE-2026-94483 — SSRF na Otimização de Imagens

CVE-2026-94483	ALTA · Alta (sem CVSS no blog)
Aviso	GHSA-cjq9-62q9-8jv4
Condição	Somente com `images.remotePatterns` configurado
Corrigido em	15.5.27 e 16.3.8

O que identifica

Uma URL remota permitida pelo `remotePatterns`, mas controlada pelo atacante, pode levar o servidor a requisitar endereços internos (ex.: faixas de IP privadas) durante a otimização — provavelmente via redirecionamento, embora o aviso não detalhe.

Impacto

O atacante usa o servidor Next.js para alcançar a rede interna ou o serviço de metadados da nuvem (`169.254.169.254`), de onde pode obter credenciais.

Correção e mitigação

Atualizar. Restringir `remotePatterns` a domínios sob seu controle e bloquear, na rede, o acesso do servidor ao endpoint de metadados.

5.2 Demais falhas de setembro

ID / gravidade	O que identifica	Quem é afetado
CVE-2026-94543 · Média	O cache de uma página SSG/ISR pode ser substituído pelo conteúdo de outra rota; todos os visitantes recebem a página errada até a revalidação.	Self-hosted com Pages Router e SSG/ISR. Vercel não afetada.
CVE-2026-94484 · Média	Uma única requisição sem autenticação envenena o cache compartilhado: conteúdo trocado entre usuários e DoS persistente.	Apps com página catch-all na raiz ([...slug]) + rotas SSG/ISR.
CVE-2026-94485 · Média	Rotas de imagem de metadata (`opengraph-image`, `twitter-image`) ignoram `dynamicParams`, gerando imagens para segmentos que deveriam estar bloqueados.	App Router compilado com webpack (Turbopack não afetado).
GHSA-h694-7cp9-m8p3 · Média	Função use cache que chama outra que lê um root param gera chave de cache sem esse parâmetro: conteúdo de um valor servido para outro (não controlável pelo atacante).	Cache Components habilitado.
CVE-2026-94544 · Média	Preenchimentos pendentes de use cache são compartilhados entre requisições de Draft Mode e normais: visitantes podem receber conteúdo não publicado, que pode ser gravado na página gerada.	Cache Components + Draft Mode com conteúdo dependente do rascunho.
CVE-2026-94486 · Baixa	O endpoint MCP do `next dev` não verifica a origem: um site malicioso visitado pelo desenvolvedor lê caminho do projeto, trechos de código, rotas e logs.	Somente servidor de desenvolvimento; produção não expõe o endpoint.

6. Lançamento de 21/07/2026 (primeiro programado)

Versões **16.2.11** e **15.5.21** (e canários da 16.3). Previsto para 20/07 e adiado em um dia. Trouxe 4 falhas altas e 5 médias.

CVE / gravidade	O que identifica	Condição
CVE-2026-64641 · Alta	Requisições forjadas a Server Actions consomem CPU e bloqueiam o processo (DoS).	App Router + ao menos uma Server Action.
CVE-2026-64642 · Alta	Bypass do middleware/proxy — e portanto de qualquer checagem de autenticação feita nele.	App Router compilado com Turbopack e apenas uma entrada em `i18n.locales`.
CVE-2026-64645 · Alta	Regra de `rewrites()`/`redirects()` que monta o host de destino com dados da requisição pode ser apontada para qualquer host, ignorando o sufixo: SSRF (rewrites) ou open redirect (redirects).	Regras com host de destino dinâmico.
CVE-2026-64649 · Alta	Quando uma Server Action encaminha ou redireciona a requisição, o atacante controla o host de destino via cabeçalhos ligados ao Host: SSRF.	Servidores customizados.
CVE-2026-64644 · Média	SVGs maliciosos esgotam a CPU no `/_next/image`.	Self-hosted com otimização de imagens remotas (não é o padrão).
CVE-2026-64646 · Média	Payload de Server Action sem limite consome memória.	Server Actions no Edge runtime.
CVE-2026-64643 · Média	IDs internos de Server Actions e de endpoints use cache ficam expostos globalmente — útil para reconhecimento e encadeamento de ataques.	App Router.
CVE-2026-64648 · Média	Um `fetch` no servidor com corpo pode receber a resposta em cache de outra requisição com corpo diferente.	Só no formato `fetch(new Request(init), outroInit)`.
CVE-2026-64647 · Média	Mesma confusão de cache quando o corpo tem bytes UTF-8 inválidos (sequências diferentes geram a mesma chave).	Corpos com bytes inválidos.

7. Recomendações práticas

Correção

- Ver a versão instalada: `npm ls next sharp` (ou `pnpm why next`). Em produção, conferir a versão dentro da imagem Docker ou do build implantado.
- Atualizar: `npm install next@16.4.1` ou `npm install next@15.5.28`; conferir `sharp` ≥ 0.35.5; refazer o build, publicar e reiniciar.
- Projetos em Next.js 14 ou anterior: planejar migração para 15.5 ou 16 — não há correções para esses ramos.
- Self-hosting: atualizar também o Node.js para a versão de 21/10/2026 (falha crítica no Brotli, CVE-2026-111497) e reconstruir a imagem base.
- Acompanhar os pré-anúncios no blog do Next.js para reservar janelas de atualização.

Redução de superfície

- Se a Otimização de Imagens não é necessária: `images: { unoptimized: true }` ou um loader externo (CDN de imagens).
- Se é necessária: `remotePatterns` restrito a domínios próprios, `dangerouslyAllowSVG` desligado e limites de recurso no contêiner.
- Não confiar apenas no middleware para autenticação: verificar a sessão também nas rotas, Server Actions e APIs (defesa em profundidade, por causa de bypasses como a CVE-2026-64642).
- Não montar hosts de `rewrites`/`redirects` com dados da requisição; validar cabeçalhos `Host`/`X-Forwarded-Host` no proxy.
- Evitar hospedar em Windows quando possível; se necessário, priorizar as atualizações.
- Não expor `next dev` na rede e não navegar em sites desconhecidos com o servidor de desenvolvimento aberto.

Detecção (Blue Team)

- Picos de CPU e reinícios do processo Node ligados a POSTs com cabeçalho `Next-Action` (DoS de Server Actions).
- Requisições ao `/_next/image` com URLs de domínios incomuns, SVG ou AVIF, e conexões de saída do servidor para IPs internos ou `169.254.169.254` (SSRF).
- Processos filhos inesperados do `node` (sinal de RCE) e arquivos novos no diretório da aplicação.
- Diferenças de conteúdo entre usuários ou páginas trocadas no cache (envenenamento de cache SSG/ISR).

Fontes de pesquisa

Consultadas em 23/10/2026. O blog do Next.js e os GitHub Security Advisories do repositório vercel/next.js são as fontes primárias.

Vercel / Next.js (oficiais)

[1] Next.js Security Update for Upstream Vulnerabilities (14/10/2026)
`https://nextjs.org/blog/nextjs-security-update-october-14-2026`

[2] September 2026 Security Release
`https://nextjs.org/blog/september-2026-security-release`

[3] August 2026 Security Release
`https://nextjs.org/blog/august-2026-security-release`

[4] Update: August Next.js Security Release
`https://nextjs.org/blog/nextjs-security-release-august-2026-update`

[5] July 2026 Security Release
`https://nextjs.org/blog/july-2026-security-release`

[6] Next.js Security Release and Our Next Patch Release (programa de segurança)
https://nextjs.org/blog/next-security-release-program

[7] GitHub Advisory GHSA-673q-mjm6-r5xr (use cache RCE)
https://github.com/vercel/next.js/security/advisories/GHSA-673q-mjm6-r5xr

[8] GitHub Advisory GHSA-2464-fhr4-w9xw (CVE-2026-96889)
https://github.com/vercel/next.js/security/advisories/GHSA-2464-fhr4-w9xw

[9] GitHub Advisory GHSA-p3m5-59mp-jv5r (Server Actions DoS)
https://github.com/vercel/next.js/security/advisories/GHSA-p3m5-59mp-jv5r

[10] GitHub Advisory GHSA-2xp9-vwfh-vxw4 (AVIF RCE)
https://github.com/vercel/next.js/security/advisories/GHSA-2xp9-vwfh-vxw4

[11] GitHub Advisory GHSA-p293-qw3h-jr36 (CVE-2026-75604)
https://github.com/vercel/next.js/security/advisories/GHSA-p293-qw3h-jr36

[12] GitHub Security Advisories — vercel/next.js
https://github.com/vercel/next.js/security/advisories

Outras fontes

[13] CSA Singapore — Critical Vulnerabilities in Next.js (AL-2026-148)
https://www.csa.gov.sg/alerts-and-advisories/alerts/al-2026-148/

[14] NVD — CVE-2026-96889
https://nvd.nist.gov/vuln/detail/cve-2026-96889

[15] SecurityOnline — Next.js Fixes Two Critical Unauthenticated RCE Flaws
https://securityonline.info/nextjs-security-update-rce-october-2026/